

BRIEFINGS

black hat

GitHub Can Tell You're Being Hacked. You're Just Not Listening :
Building EDR for GitHub from Its Own Event Stream

whoami



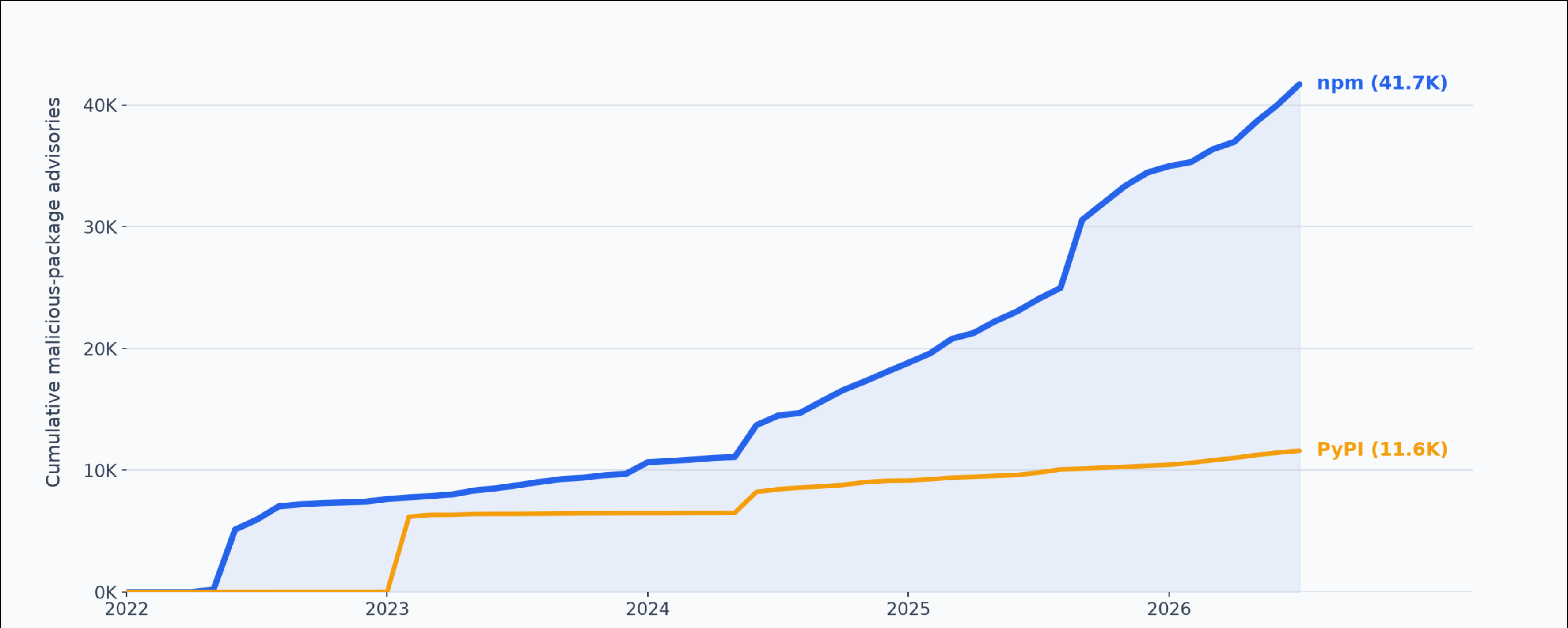
Mor Weinberger
Software Architect



Yossi Weizman
Principal Security Researcher



Why Now



Based on OSV data

Why Now

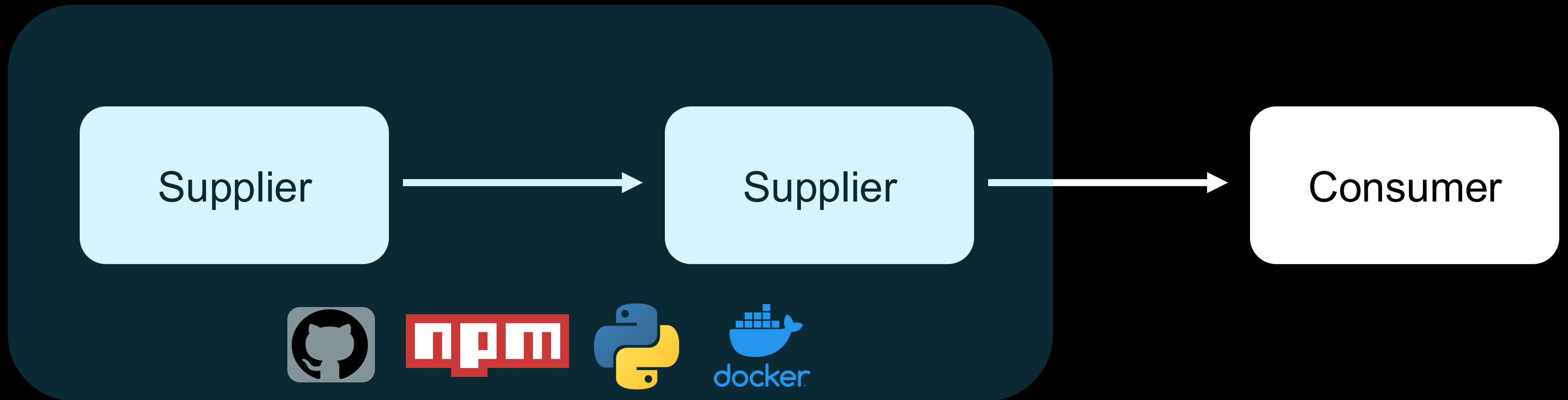
Recent notable incidents



What's in Our Scope?

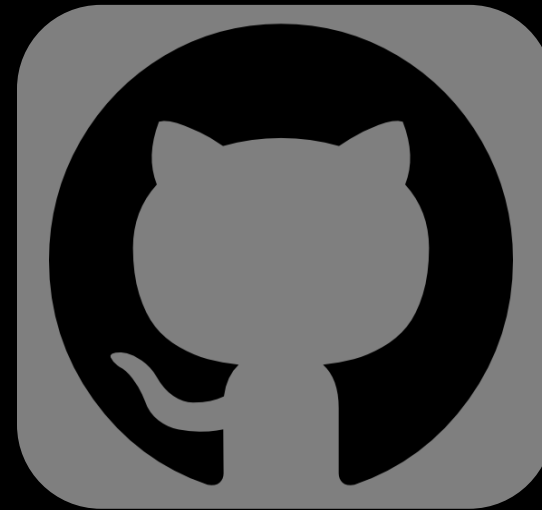


What's in Our Scope?



What's in Our Scope?

In this session, we will focus on GH-related attacks



Many attacks – same techniques

Artifact poisoning

Mass tag push

Temporary tag swap

Malicious release

OIDC abuse

Registry trusted-publish abuse

Cloud OIDC federation abuse

Workflow injection & Trigger abuse

pull_request_target abuse

Direct workflow override

Secrets exfiltration in workflow logs

Cache poisoning

Runner's memory dump

Identity & commit-metadata forgery

Forged maintainer's identity

Forged app's identity

Forged timestamp and parent commits

Forged commits tree

Evidence destruction

Delete workflow runs

Delete forks & branches

Remove user

Disable webhooks

Code & artifact revert

Base repo commit URL

Malicious code injected via fork\off-repo

Malicious code stored in fork

Malicious code stored in a dangling commit

Malicious code in a temporary branch

Many attacks – same techniques

Mass tag push	Trivy	tj-actions	codfish		
Temporary tag swap	reviewdog				
Forged maintainer's identity	Trivy	tj-actions	megalodon	TanStack	RedHat
Forged app's identity	tj-actions	TanStack			
Forged timestamp & parent commits	Trivy	PolinRider			
Forged commits tree	Trivy				
Off-branch commit	tj-actions	reviewdog	TanStack	RedHat	
Malicious code in a temporary branch	Bitwarden				
pull_request_target abuse	TanStack	AsyncAPI			
Direct workflow override	megalodon	Bitwarden	RedHat		
Secrets exfiltration in workflow logs	tj-actions	reviewdog			
Cache poisoning	TanStack				
Runner's memory dump	Trivy	reviewdog	tj-actions	TanStack	
Delete workflow runs	Bitwarden				
Delete forks & branches	reviewdog	Bitwarden	TanStack		
Remove user	reviewdog				
Disable webhooks	reviewdog				
Code & artifact revert	reviewdog	TanStack			
Base repo commit URL	TanStack				
Registry trusted-publish abuse	TanStack	Bitwarden	RedHat	AsyncAPI	

Trivy

tj-actions

reviewdog

megalodon

Bitwarden

TanStack

RedHat

PolinRider

codfish

AsyncAPI

TTPs - examples

GIT metadata forgery

GIT metadata can be set to any value

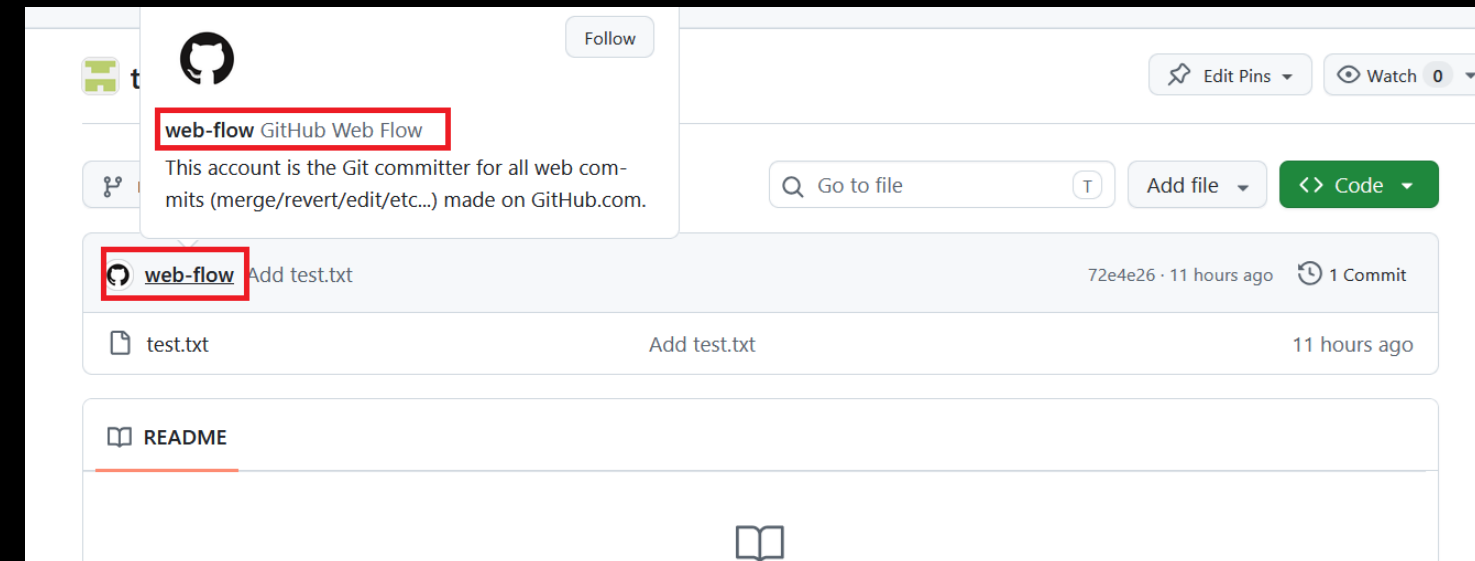
```
author      name | email | date
committer   name | email | date
message · tree · parent(s)
```

The pusher is the authenticated user with GH. This is the field you can trust.

Detection: **compare the author's name to the authenticated user**

```
author = head_commit.author.username ← from the commit (forgeable)
pusher = sender.login                 ← authenticated by GitHub (trusted)
flag when author ≠ pusher
```

GitHub resolves the author.email field to its legitimate GitHub (clickable + avatar)



```
$ git config user.name "web-flow"
$ git config user.email "...@users.noreply.github.com"
$ git commit -m "Add test.txt"
```

Activity

All branches ▾ All activity ▾ All users ▾ All time ▾

Add test.txt

yow9 created main • b39f4c6 • 1 minute ago

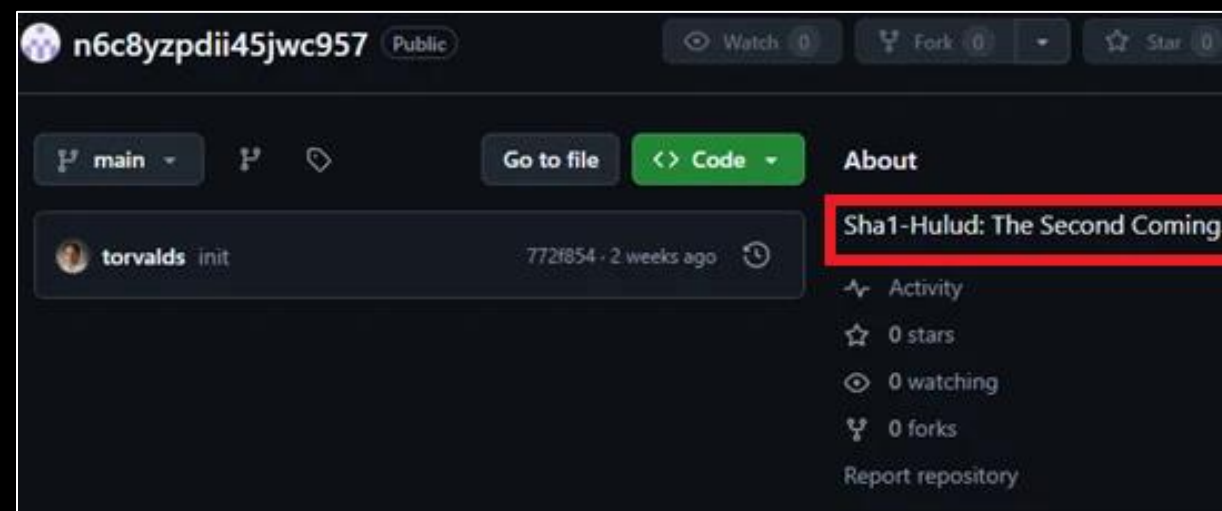
[Share feedback about this page](#)

TTPs - examples

Cross-org forged-author correlation

Attacks are often automated. Attackers use same forged identities against multiple victims.

Forged identities in the repo which appear in other repos as well – **is a strong indication of compromise.**
Seen also in: Shai-Hulud, Megalodon



The reused email is indexed by GitHub - pivot from one repo to the whole campaign:

```
GET /search/commits
?q=author-email:x@fake.dev
```

Detection: Find large-scale forged identities using GH Search API

For each commit where author $\neq$ pusher:

GET /search/commits?q=author-email → collect owners
alert if same email spans $\geq x$ unrelated owners (orgs\users)

TTPs - examples

Mass tags push

Goal: move many release tags onto one poisoned commit, so every workflow that pins the action by tag (`uses: org/action@vN`) runs the malicious code.

```
$ git tag -f v1 v2 v3 ... v46 <poisoned>
$ git push --force origin --tags
```

Tags are movable (mutable) pointers

Reliable detection must track tag changes via tags API:

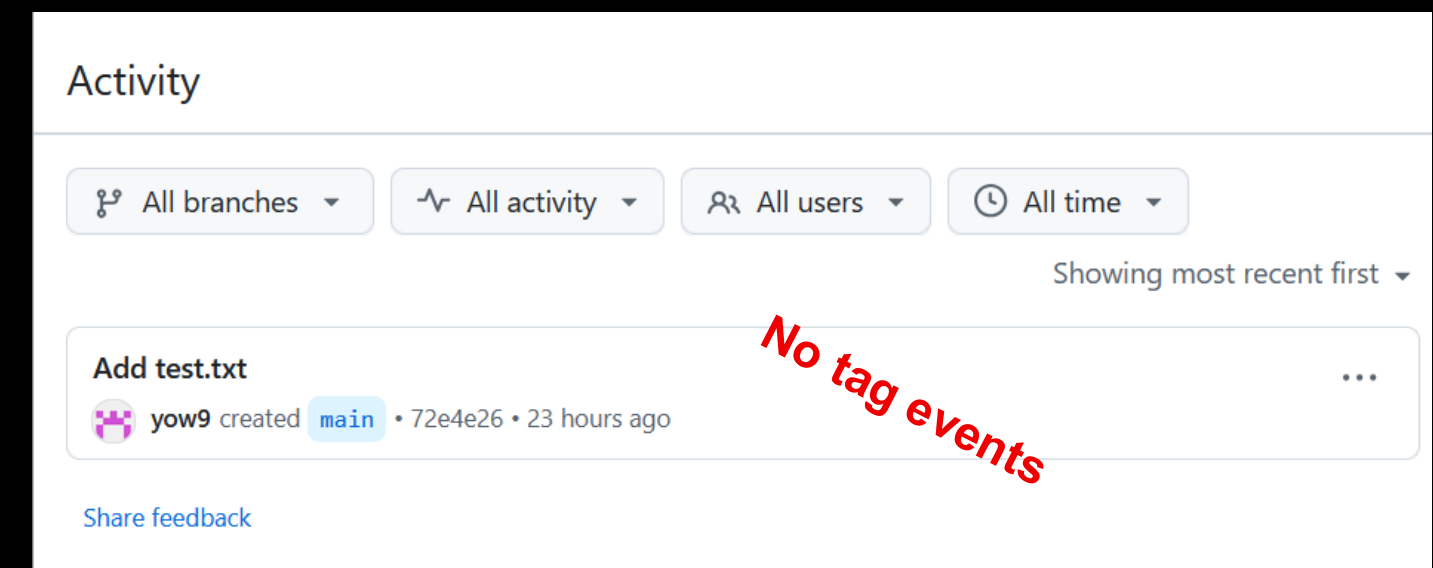
`GET /repos/{owner}/{repo}/git/refs/tags`

→ store SHA per tag

`old_sha` $\neq$ `new_sha` $\Rightarrow$ tag moved.

Many tag changes = potentially mass tag poisoning

Tag pushes aren't visible in GitHub Activity:



They are logged in webhooks, but....



Events will not be created if more than 5000 branches are pushed at once. Events will not be created for tags when more than three tags are pushed at once.

<https://docs.github.com/en/webhooks/webhook-events-and-payloads#push>

TTPs - examples

OIDC abuse

Old way: workflow publishes with a stored token (**NPM_TOKEN** in GitHub Secrets)

OIDC: workflow with **id-token: write** mints its own short-lived token to authenticate with the cloud / registry.

→ **The workflow IS the identity.**

The attacker's goal shifts:

Steal a secret → Get an OIDC-granting workflow to run

Modify a workflow that grants OIDC, and get it to run:

```
on: push
permissions:
  id-token: write
```

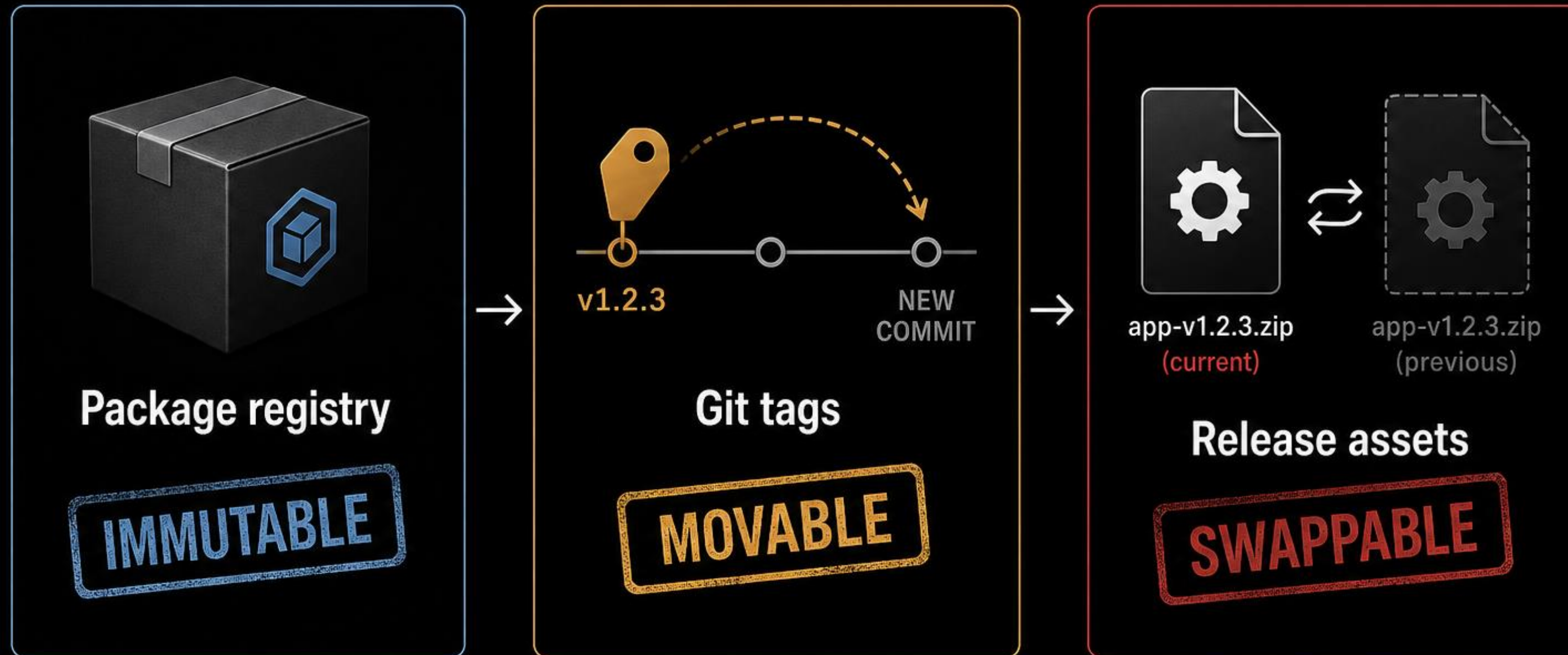
Detection: track new or modified workflows that mint OIDC tokens

Examples:

- Direct push to publishing workflow
- Token read from risky workflow (e.g. pull_request_request)

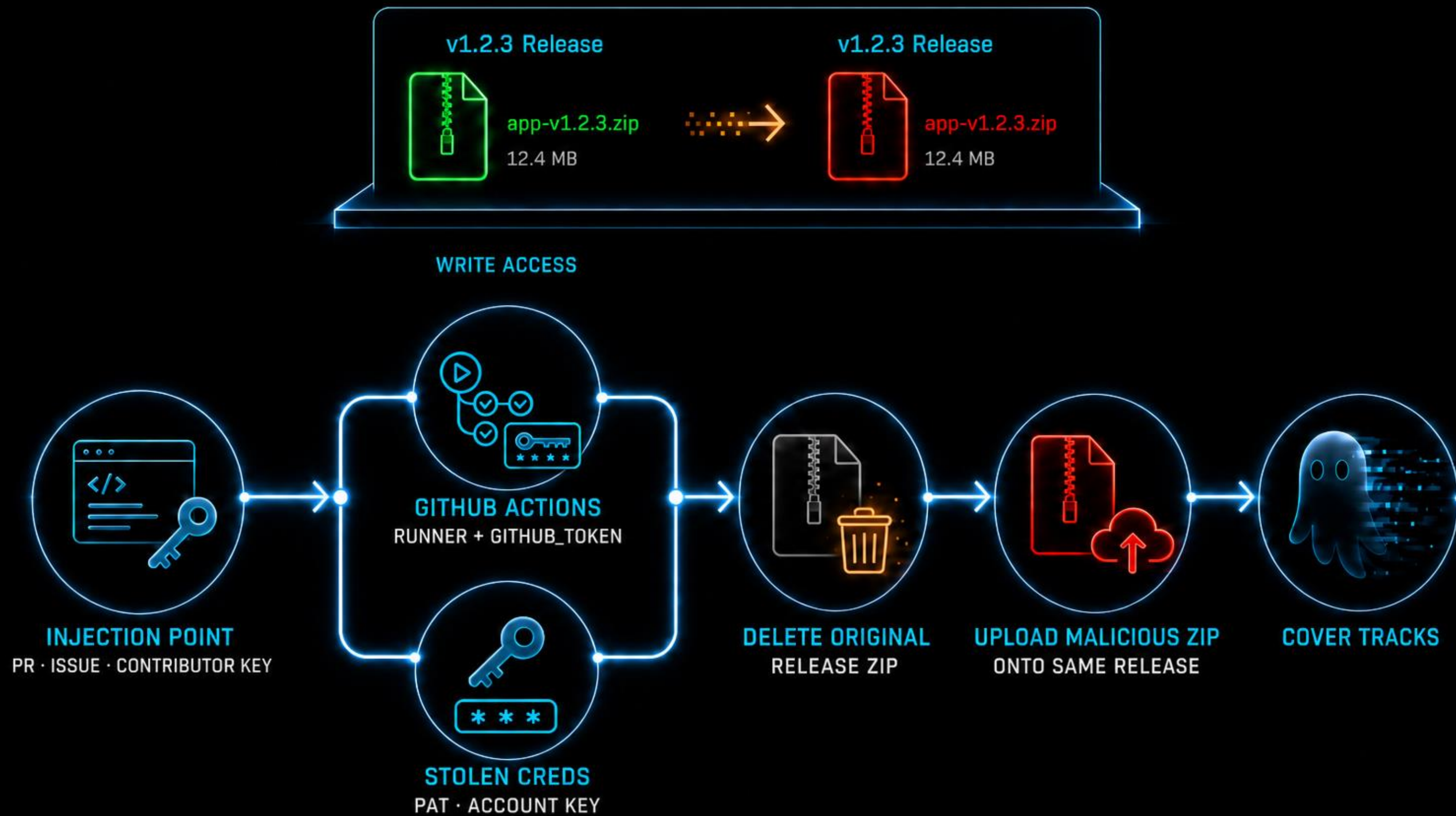
The image shows two overlapping screenshots from the GitHub web interface. The background screenshot is the 'Trusted Publisher' configuration page, which includes fields for 'Publisher*' (set to GitHub Actions), 'Organization or user*', 'Repository*', 'Workflow filename*', 'Environment name', and 'Allowed actions *'. The foreground screenshot is the 'Add Federated Credential' modal, which includes a 'Federated credential scenario' dropdown (set to 'Configure a GitHub issued token to impersonate this application and deploy to Azure'), a 'Connect your Github account' section with fields for 'Issuer', 'Organization', 'Repository', 'Entity', and 'Subject identifier', and a 'Credential details' section with 'Name' and 'Audience' fields.

Same trust. Different object

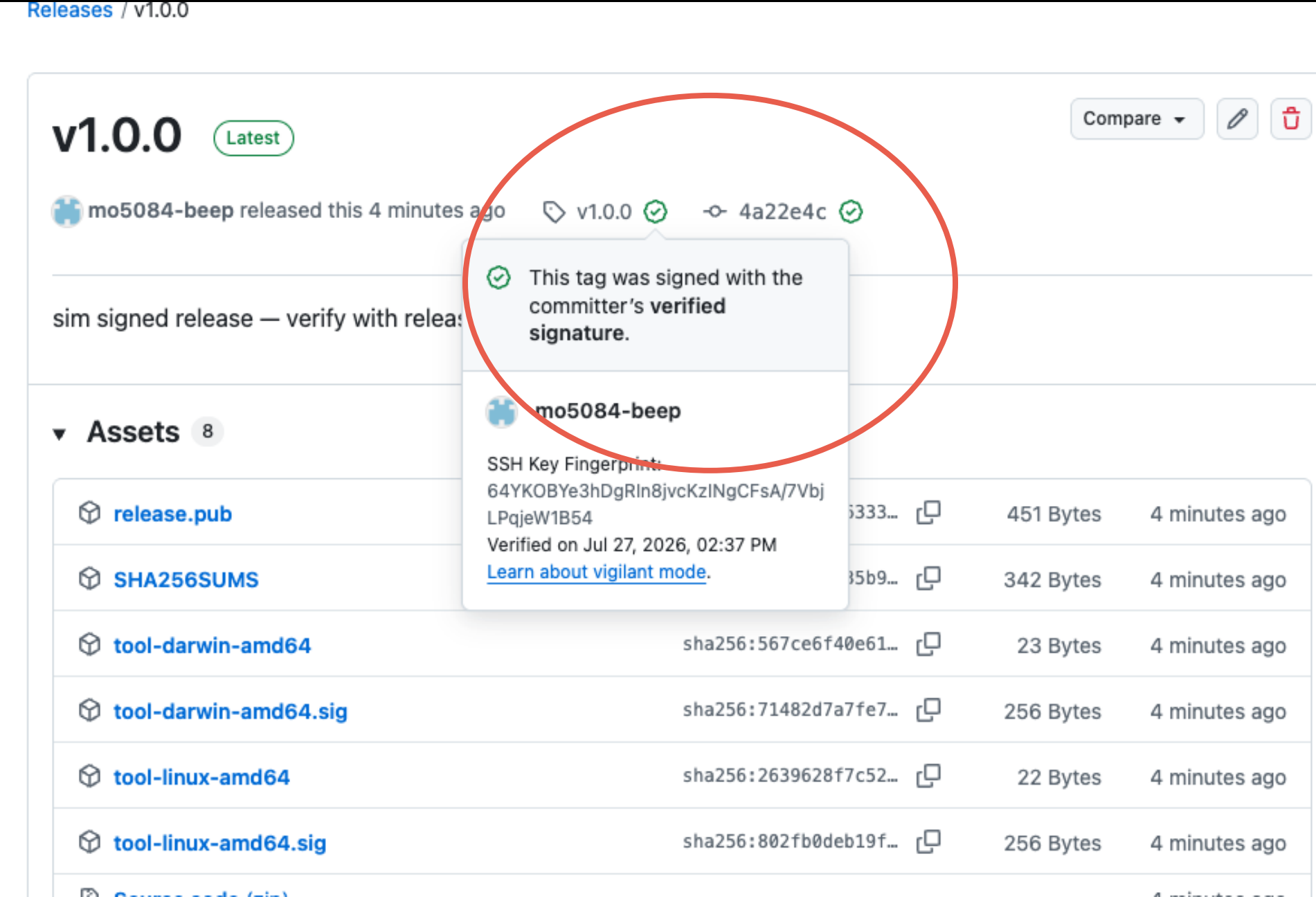


Same version string. Three different trust models.

Implant into an existing release



Tampered Release Artifacts



What the UI answers

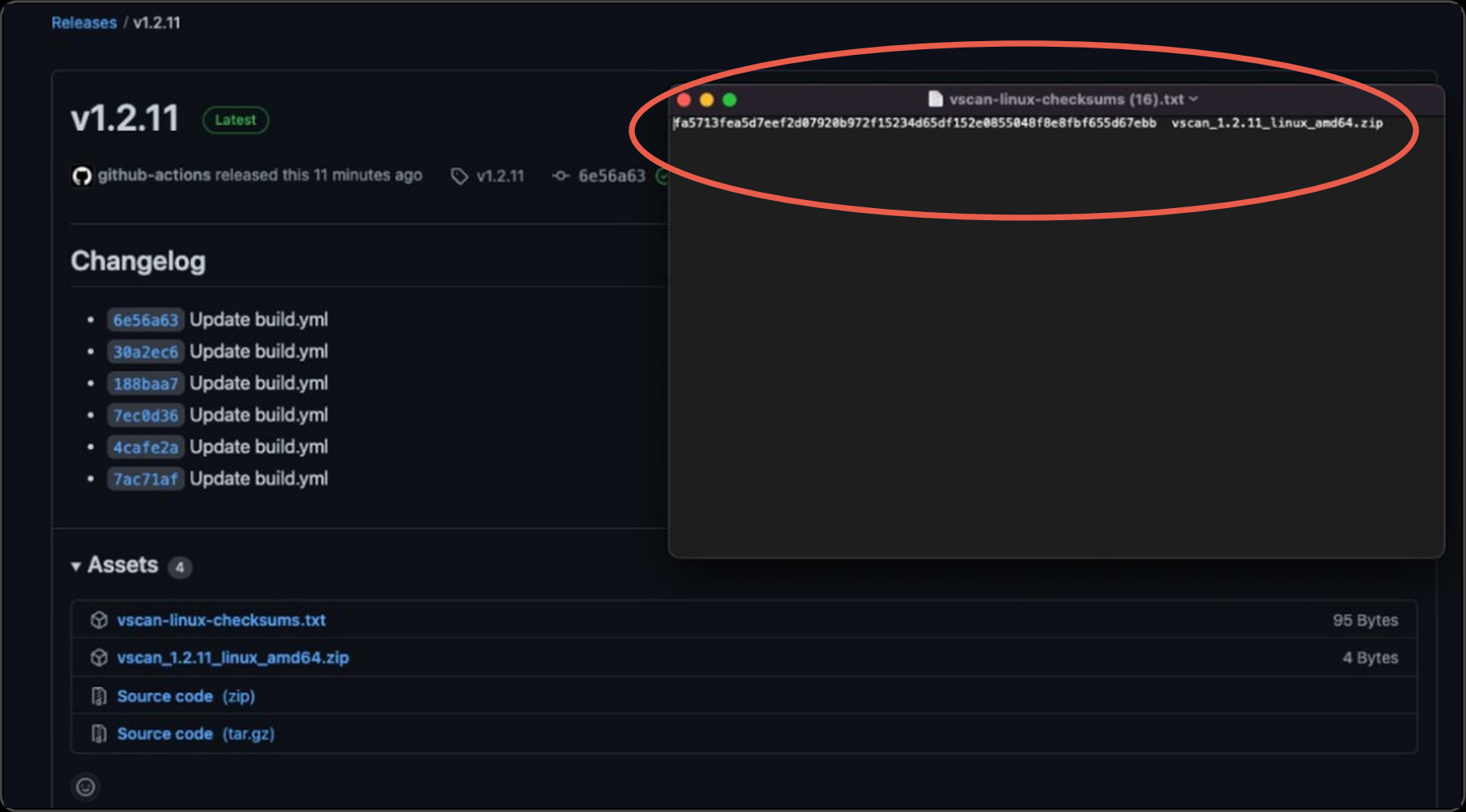
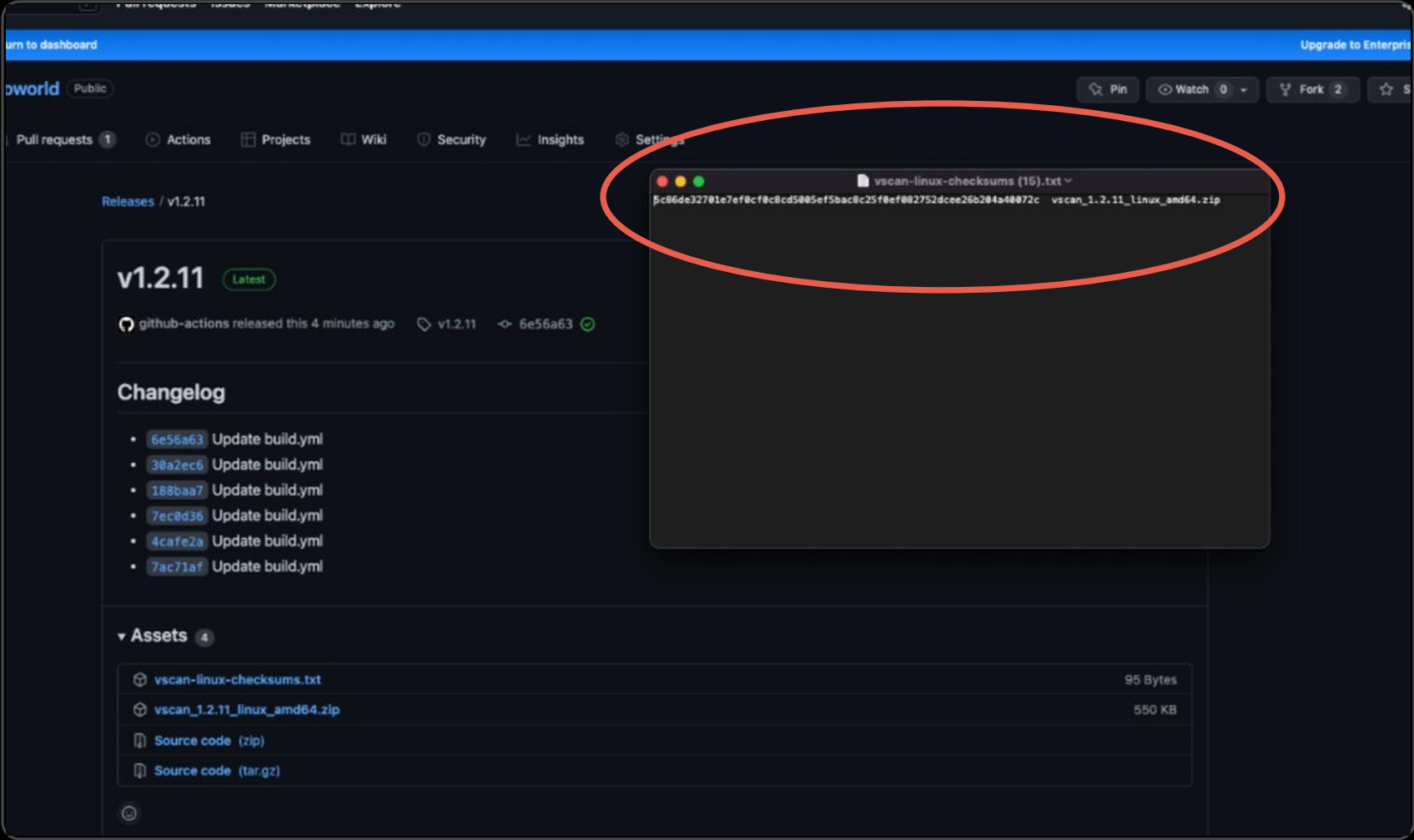
Who signed the commit at the first place
Key known to GitHub

What it does not

Release maturity
Whether assets were swapped

Verified ≠ trustworthy binary

Same trust chrome. Different maturity.



Checksums prove integrity of whatever was uploaded - including malware.

Report to Github Bug bounty

Although this warning does not explicitly mention releases, it does state that the GITHUB_TOKEN is granted write permissions on the repository, [which is all that is required to create, edit, and delete releases](#).

Based on the feedback you've provided here, I've added the suggestion to add timestamps to release assets to our internal feature request list, and the team is actively working to make these improvements to the GitHub interface:

I think you should emphasize the creation time and modify the time of the assets on the release page

We greatly appreciate the thoroughness of this report and the improvement suggestions made throughout, so we'd like to offer you a small reward as thanks.

Report → Signal → Detection



Intended behavior. New metadata. Detectable swap.

Tampered Release Artifacts

v1.0.0

Latest

Compare

mo5084-beep

released this 12 minutes ago

v1.0.0

4a22e4c

v1.0.0

Assets

8

release.pub	sha256:6f93259...		451 Bytes	12 minutes ago
SHA256SUMS	sha256:a531362...		342 Bytes	12 minutes ago
tool-darwin-amd64	sha256:567ce6f...		23 Bytes	12 minutes ago
tool-darwin-amd64.sig	sha256:71482d7...		256 Bytes	12 minutes ago
tool-linux-amd64	sha256:2639628...		22 Bytes	12 minutes ago
tool-linux-amd64.sig	sha256:802fb0d...		256 Bytes	12 minutes ago
Source code (zip)				13 minutes ago
Source code (tar.gz)				13 minutes ago

v1.0.0

Latest

Compare

mo5084-beep

released this 12 minutes ago

v1.0.0

4a22e4c

v1.0.0

Assets

8

release.pub	sha256:6f93259...		451 Bytes	12 minutes ago
SHA256SUMS	sha256:a531362...		342 Bytes	12 minutes ago
tool-darwin-amd64	sha256:567ce6f...		23 Bytes	12 minutes ago
tool-darwin-amd64.sig	sha256:71482d7...		256 Bytes	12 minutes ago
tool-linux-amd64	sha256:31eed41...		36 Bytes	2 minutes ago
tool-linux-amd64.sig	sha256:802fb0d...		256 Bytes	12 minutes ago
Source code (zip)				12 minutes ago
Source code (tar.gz)				12 minutes ago

The Engine



github.com/supplychain-labs/github-threat-detector

The Engine

LISTEN

ingest platform activity

Webhooks

live push stream

GitHub APIs

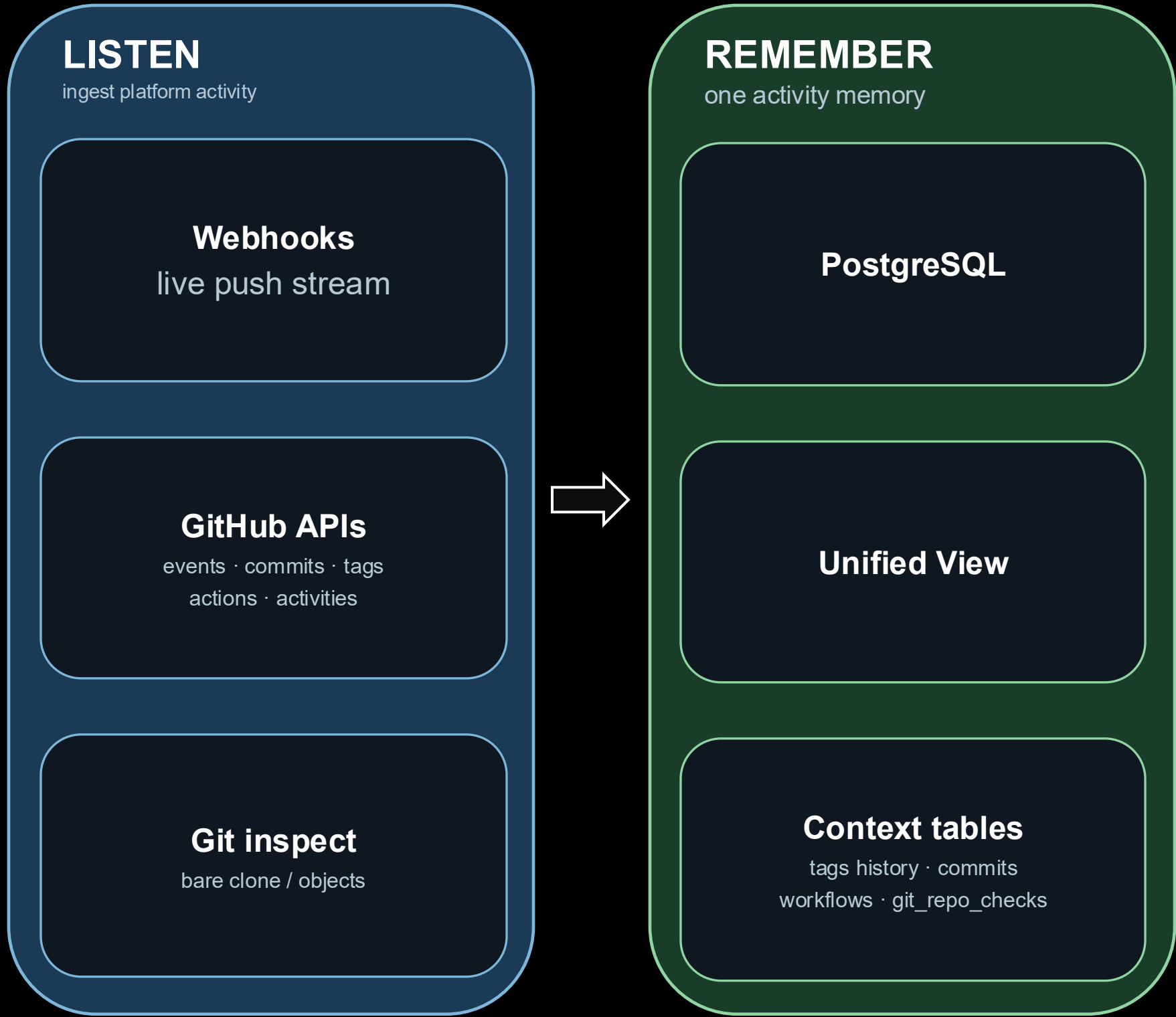
events · commits · tags

actions · activities

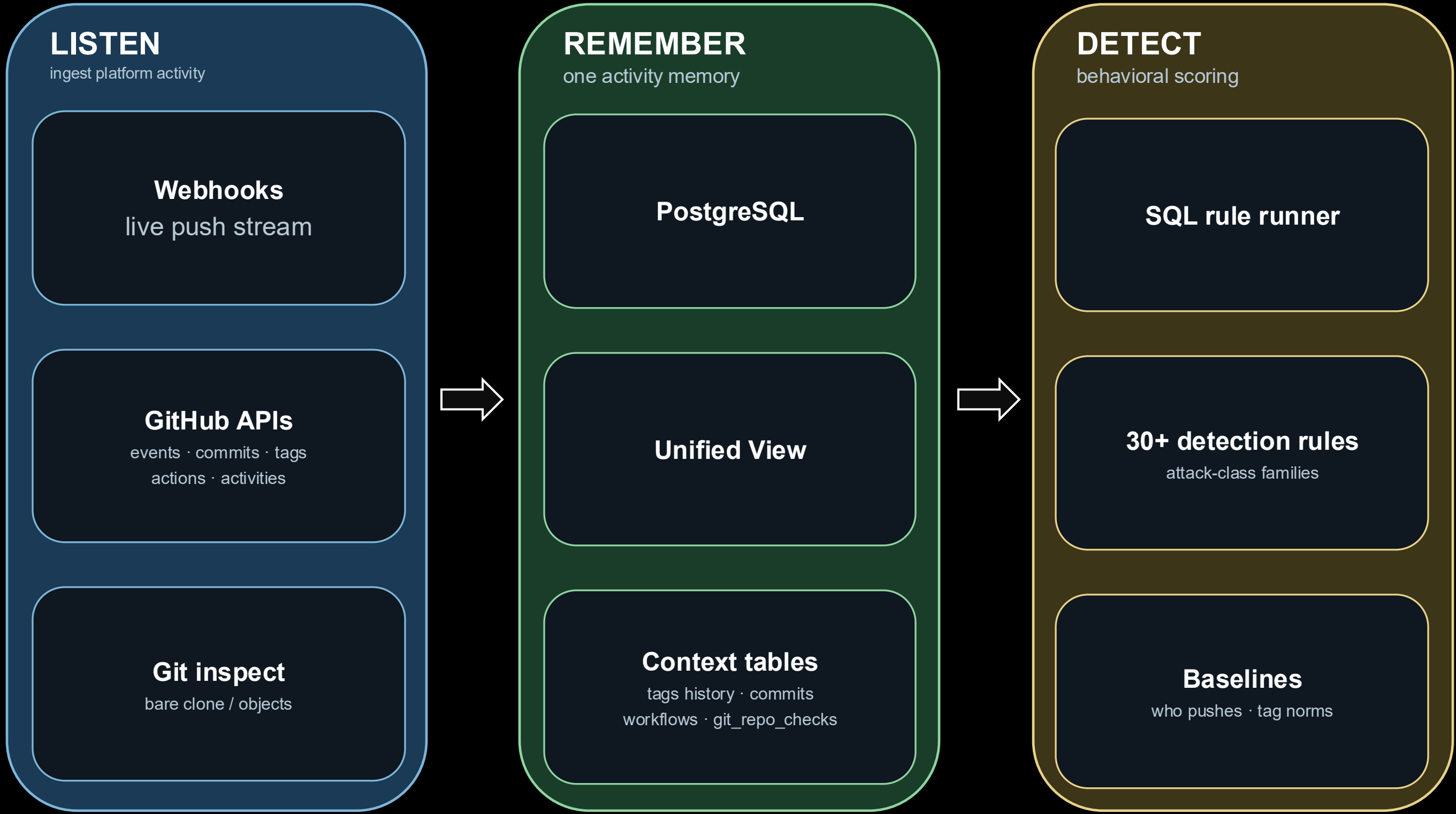
Git inspect

bare clone / objects

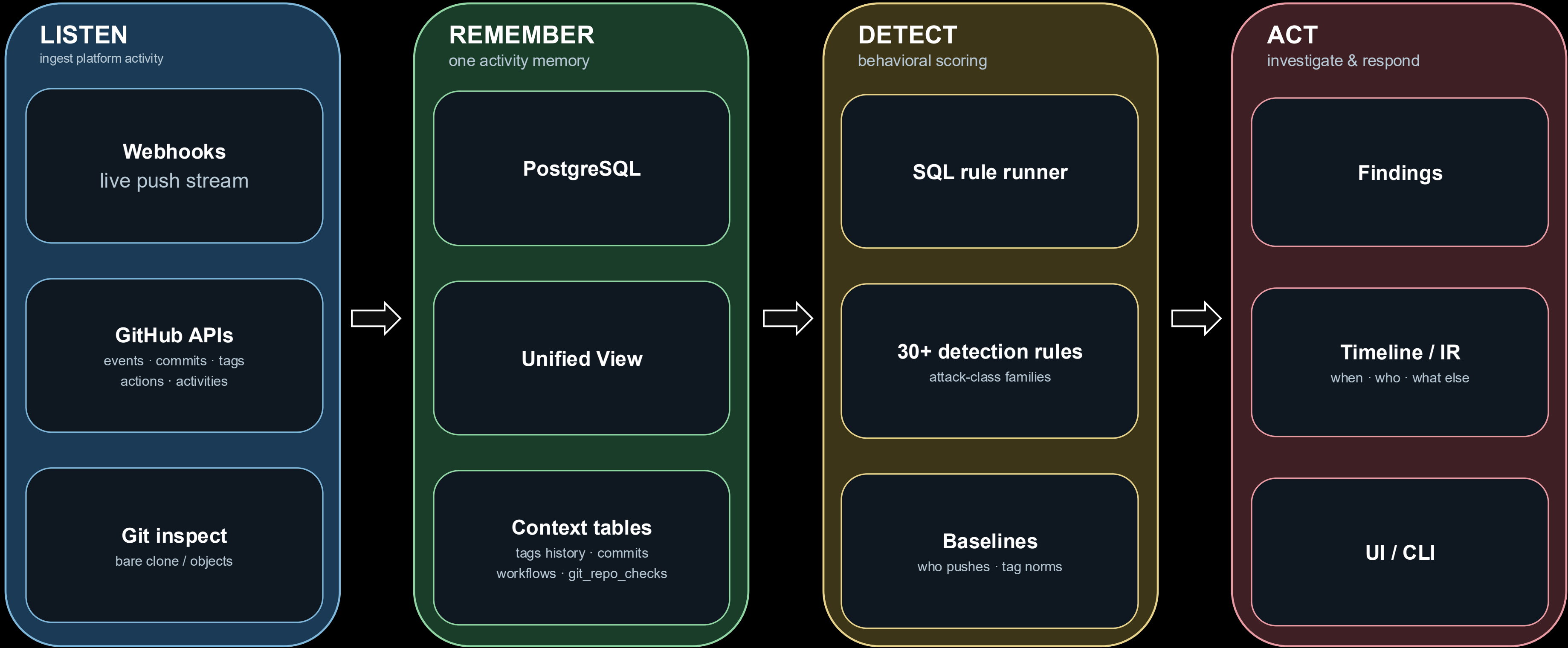
The Engine



The Engine

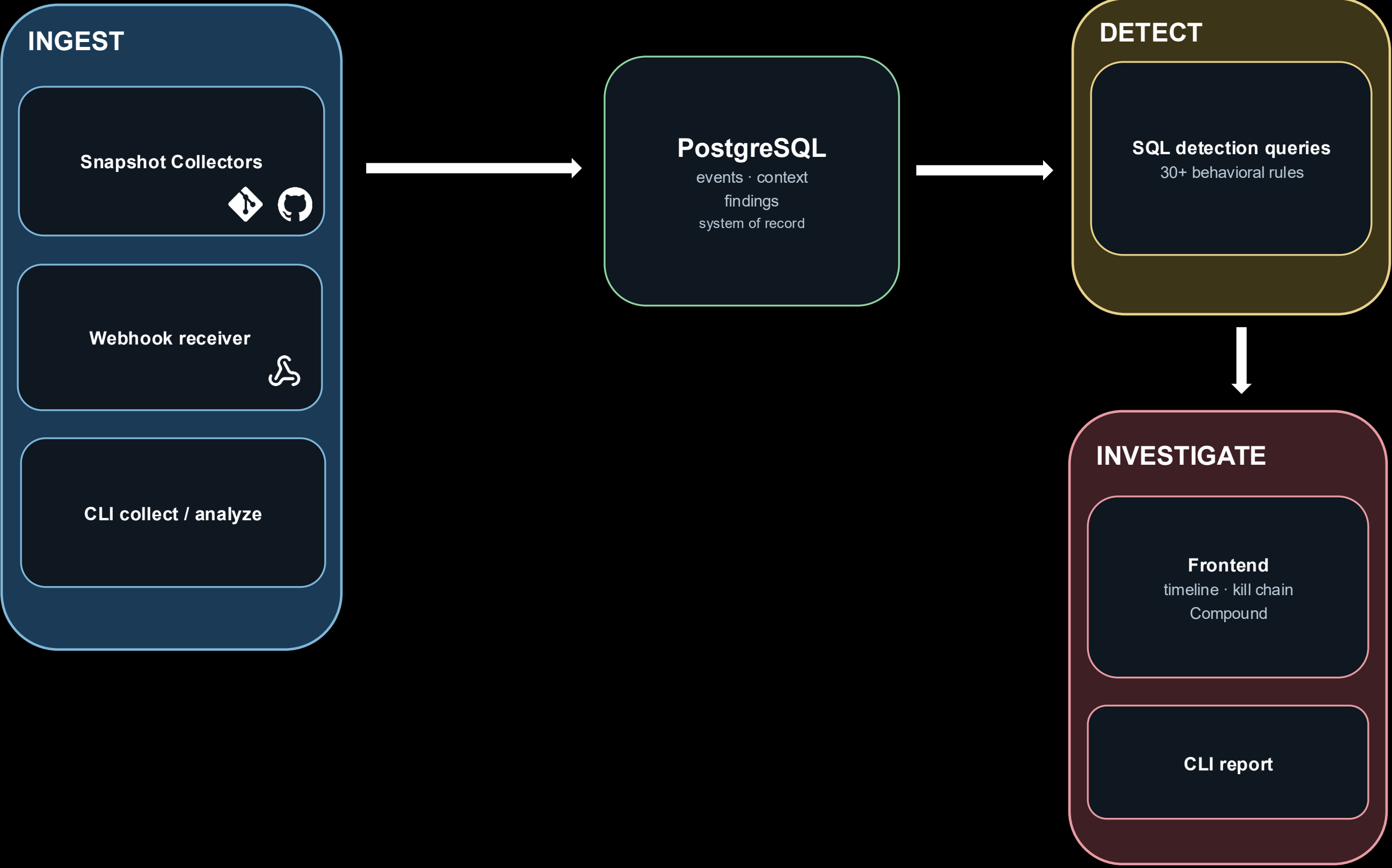


The Engine



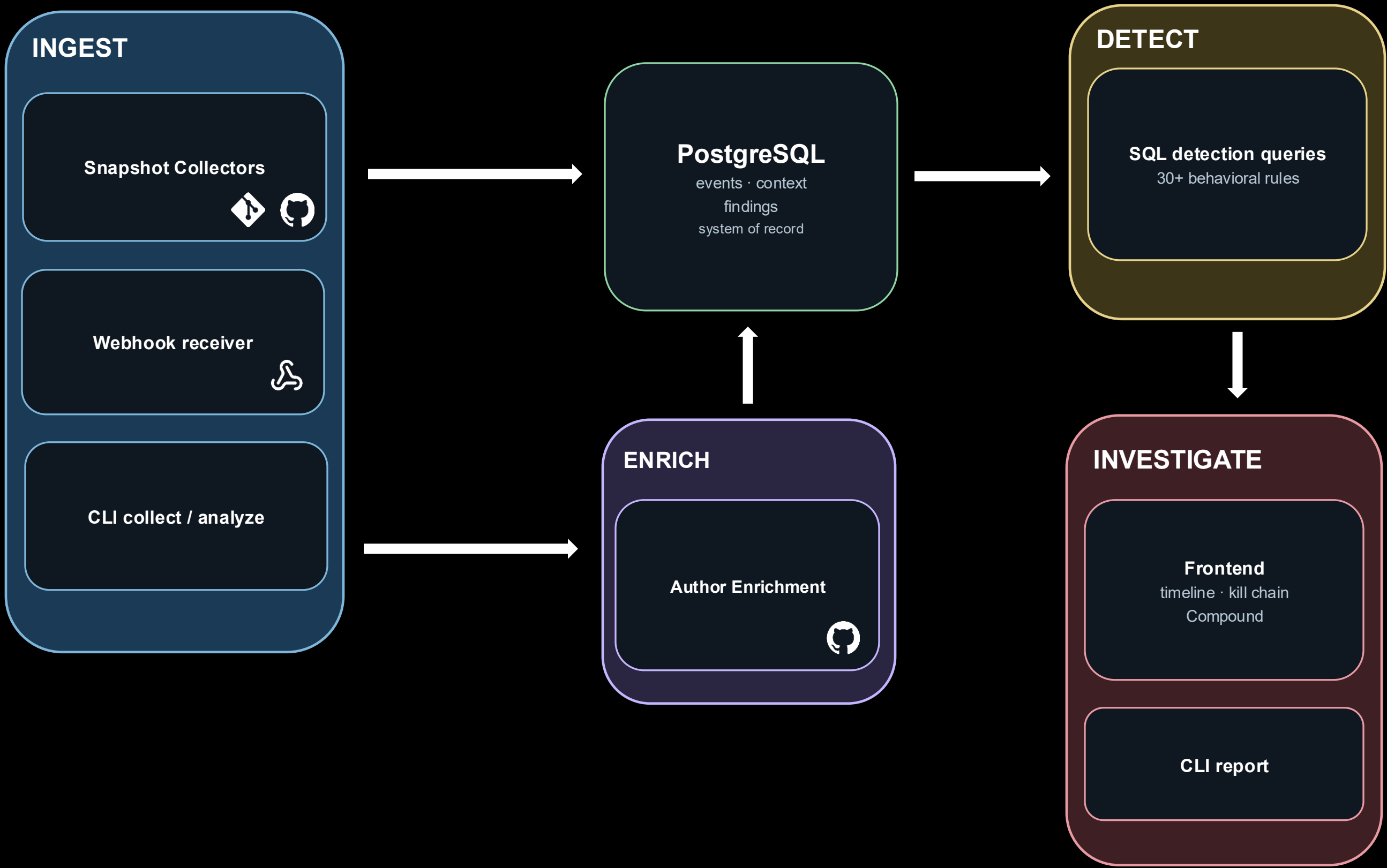
Architecture

Collect -> Enrich -> Detect -> Act



Architecture

Collect -> Enrich -> Detect -> Act



GitHub Telemetry



Webhooks

live push stream

- Real-time
- Rich telemetry
- Harder setup
- Can be disabled
- Missed events are gone

GitHub Telemetry



Webhooks

live push stream

- Real-time
- Rich telemetry
- Harder setup
- Can be disabled
- Missed events are gone



GitHub API

snapshot baseline

- Snapshot & compare over time
- Can't be removed as a channel
- API object can be removed
- Less verbose than webhooks
- Rate limited

GitHub Telemetry



Webhooks

live push stream

- Real-time
- Rich telemetry
- Harder setup
- Can be disabled
- Missed events are gone



GitHub API

snapshot baseline

- Snapshot & compare over time
- Can't be removed as a channel
- API object can be removed
- Less verbose than webhooks
- Rate limited



Git Inspect

tag provenance

- Read objects, not just events
- Great for Enrichment
- Harder to stand up
- Not real-time
- Heavier than API / webhooks

Detections

TTP family	Example of detections
Artifact poisoning	Mass tag force-push burst · Flip-flop tag · Many tags → same commit · Many tags → same parent
Identity & commit-metadata forgery	Author ≠ pusher · Committer ≠ pusher · Cross-owner forged author · Unresolvable author email · Tag parent in the future · Unverified commits
Malicious code via fork / off-repo	Tag from non-existing branch (dangling commit)
Workflow injection & trigger abuse	pull_request_target pwn-request · Direct workflow push to default · Secret base64 exfil in logs
Evidence destruction	Workflow-run deleted
OIDC abuse	OIDC risky workflow run · Direct OIDC workflow push to default branch

Overall: 22 rules + 12 beta rules

https://github.com/supplychain-labs/github-threat-detector/tree/main/analyzers/detection_queries

Detections

Blame


```

1  -- id: oidc-risky-workflow-run
2  -- severity: high → severity
3  -- description: OIDC-minting workflow '{workflow_path}' ran on untrusted trigger '{trigger}' (head_repo {head_repo}) in {repo_name}
4  -- tactic: Credential Access → MITRE ATT&CK tactic
5  -- actor: actor_login
6  -- event_id: {run_id}:{workflow_path}
7  -- evidence: workflow_path, trigger, head_branch, head_repo, run_started_at
8  -- repo_column: repo_name
9  --
10 -- Logic (workflow_runs x workflow_files):
11 --   A workflow run whose file (in workflow_files) requests id-token: write,
12 --   where the run fired on an untrusted, privileged-context trigger
13 --   (pull_request_target, workflow_run, issue_comment, PR review events) OR
14 --   the run's code came from a fork (head_repository differs from
15 --   repository). Such a run can mint an OIDC token from attacker-influenced
16 --   input executing in the base repo's context.
17 --
18 SELECT
19     r.repo_name,
20     r.id AS run_id,
21     r.workflow_path,
22     r.event AS trigger,
23     r.head_branch,
24     r.payload->'head_repository'->>'full_name' AS head_repo,
25     r.actor_login,
26     r.run_started_at
27 FROM workflow_runs r
28 JOIN workflow_files f
29     ON f.repo_name = r.repo_name
30     AND f.path = r.workflow_path
31 WHERE f.content ILIKE '%%id-token: write%%'
32     AND (
33         r.event IN ('pull_request_target', 'workflow_run',
34                     'issue_comment', 'pull_request_review', 'pull_request_review_comment')
35         OR (r.payload->'head_repository'->>'full_name')
36             IS DISTINCT FROM (r.payload->'repository'->>'full_name')
37     )

```

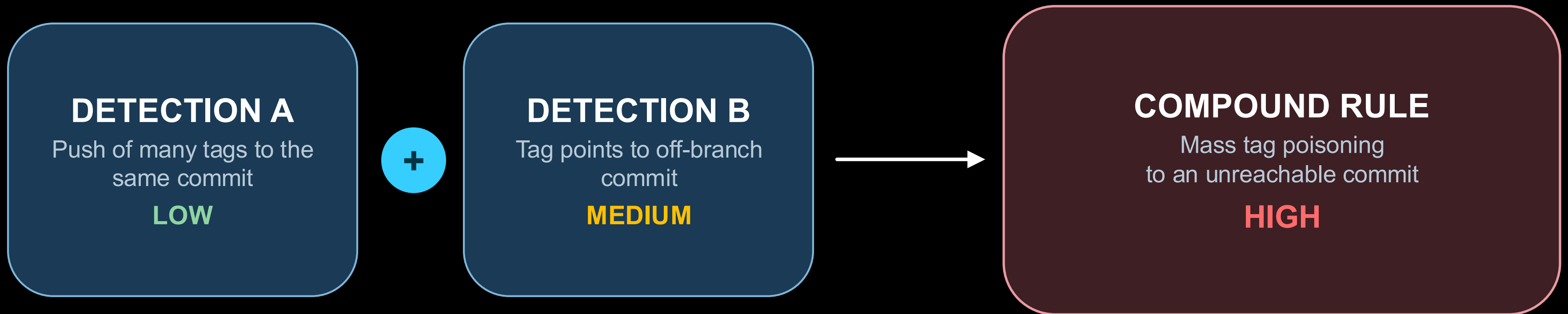
→ Detection Logic

severity

MITRE ATT&CK tactic

Detection Logic

Compound Rules

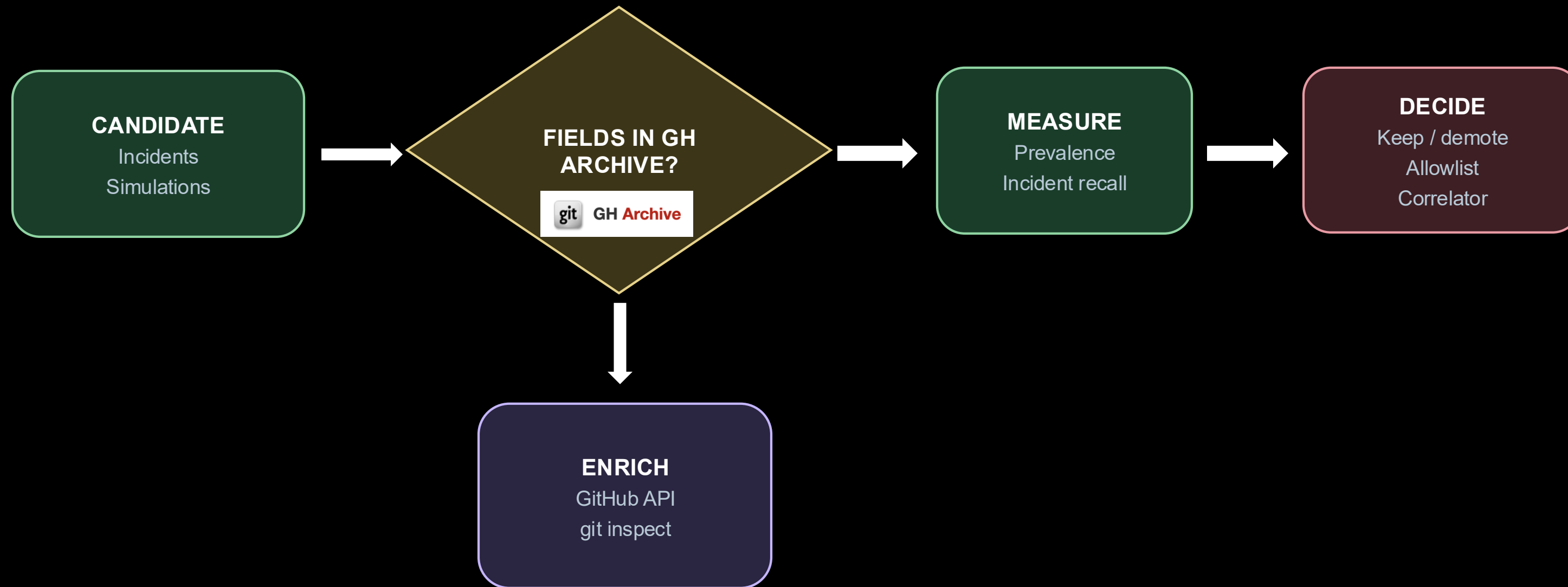


How did we evaluate it?

Simulations

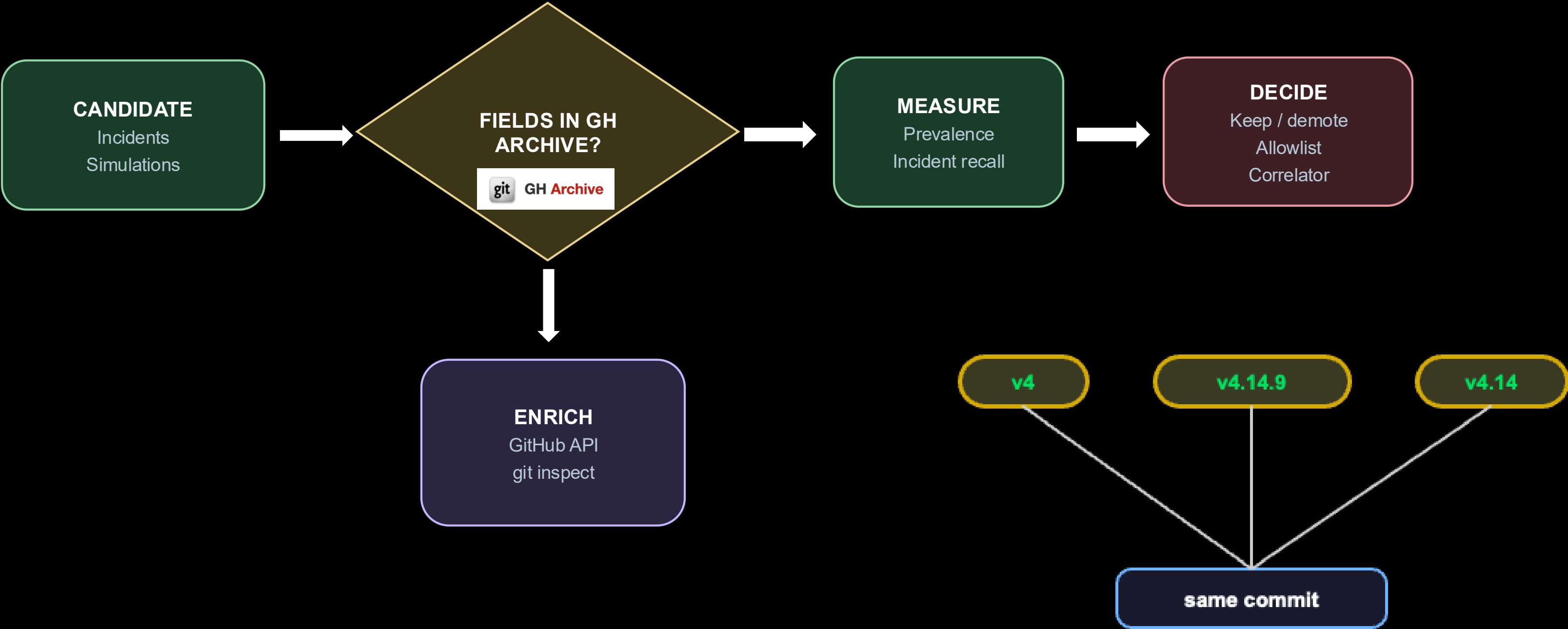
CVE-2026-33634 (trivy-actions incident)	• Author spoofed • Re-parent release commits onto today's HEAD • Mass tag force-push • Many tags → same tree / same parent • Impossible lineage (parent newer than child) • Unsigned / unverified commits on tags	Aqua Security blog Microsoft Security Blog Wiz blog
CVE-2025-30066 (tj-actions/changed-files incident)	• Malicious commit in a fork • Force-repoint all tags onto that single commit • Commit identity spoofed as a bot • Unsigned commit where baseline was signed • Tag target on no branch (off-branch / from a fork)	GH issue Step Security blog Wiz blog
CVE-2025-30154 (reviewdog incident)	• Tag v1 force-repointed to a malicious commit • Malicious commit off every branch (tag ref only) • Flip-flop cover-up: v1 reverted back to clean	GH issue Wiz blog
CVE-2026-45321 (tanstack incident)	• pull_request_target “Pwn Request”: untrusted PR ref built • Cache poisoning across fork↔base boundary • Shared cache key between PR-target and publish • Anti-forensics: PR closed + fork branch deleted • OIDC theft on the trusted runner	TanStack blog Step Security blog
CVE-2026-42994 (Bitwarden-CLI incident)	• Existing publish workflow modified on a side branch • Branch guard removed; trigger change to on: push: tags • id-token: write: registry token exchange • Stolen token echoed to run log (base64) • Unsigned commit on the publish workflow • Workflow run fires from a non-default ref (the tag) • Run + logs deleted afterward (anti-forensics)	GH issue Bitwarden community forum Step Security blog
Megalodon campaign	• Direct push to default branch, no PR (d-PPE) • Adds a backdoor under .github/workflows/ • Forged author with unresolvable email (author ≠ pusher) • Same forged author across many repos/owners in a short window • Workflow grants id-token: write	SafeDep blog

Noise lab: validating detections



<https://www.gharchive.org/>

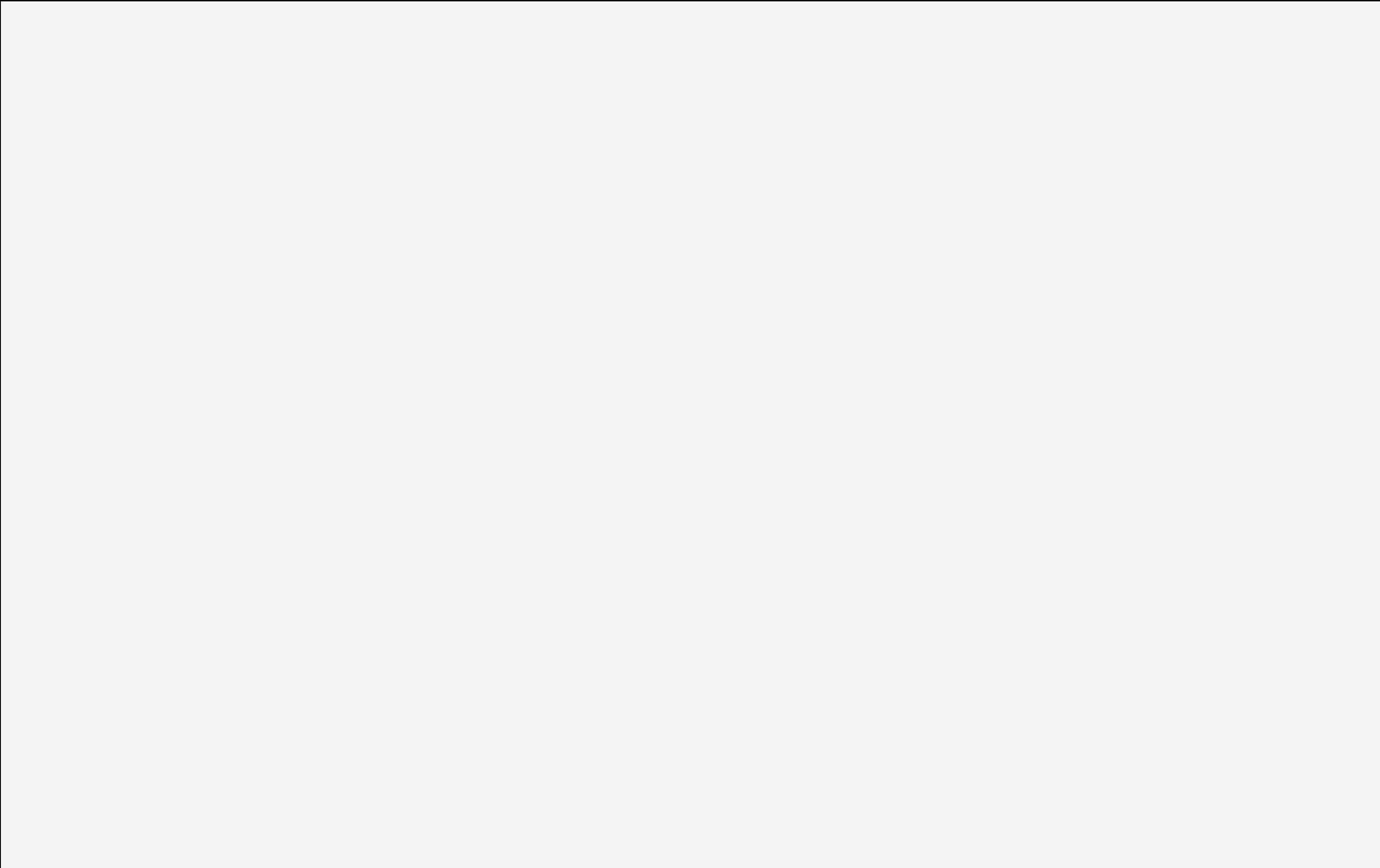
Noise lab: validating detections



<https://www.gharchive.org/>

Demo

```
sim-runner:/tmp# ./demo-trivy.sh █
```



Recent Github Hardening & Mitigations

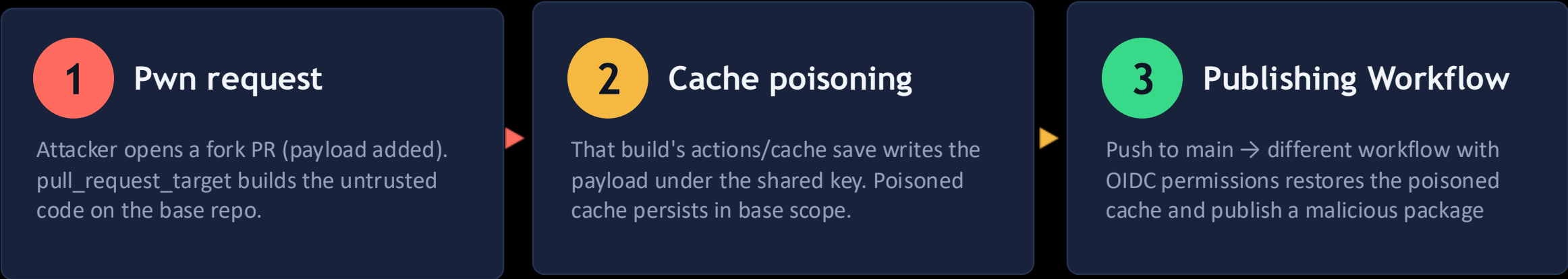
Notable recent changes:

Immutable releases (October 2025)	GitHub permanently locks Release's tag and assets so they can't be moved, edited, or deleted
Workflow execution protections (preview) (June 2026)	Central allowlist of who and which events may trigger workflows, evaluated before the run.
Safer pull_request_target defaults (June 2026)	actions/checkout now refuses to fetch fork PR code in privileged workflows unless you explicitly opt out. (default)
Read-only cache for untrusted triggers (June 2026)	Workflow runs started by non-collaborators get a cache token with read-only permission, limiting the poisoning path. (default)

Recent Github Hardening & Mitigations

Safer pull_request_target defaults (June 2026)	actions/checkout now refuses to fetch fork PR code in privileged workflows unless you explicitly opt out. (opt-out)
Read-only cache for untrusted triggers (June 2026)	Workflow runs started by non-collaborators get a cache token with read-only permission, limiting the poisoning path. (opt-out)

Example: TanStack npm supply-chain (May 2026) /simulations/sim-tanstack.sh

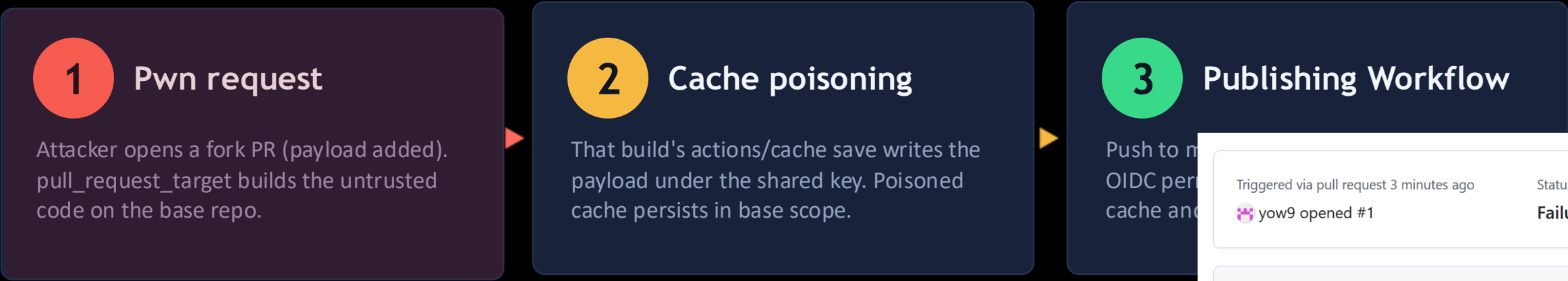


Full simulation script is here:
<https://github.com/supplychain-labs/github-threat-detector/blob/main/simulations/sim-tanstack.sh>

Recent Github Hardening & Mitigations

Safer pull_request_target defaults (June 2026)	actions/checkout now refuses to fetch fork PR code in privileged workflows unless you explicitly opt out. (opt-out)
Read-only cache for untrusted triggers (June 2026)	Workflow runs started by non-collaborators get a cache token with read-only permission, limiting the poisoning path. (opt-out)

Example: TanStack npm supply-chain (May 2026) /simulations/sim-tanstack.sh



Full simulation script is here:
<https://github.com/supplychain-labs/github-threat-detector/blob/main/simulations/sim-tanstack.sh>

Triggered via pull request 3 minutes ago

Status

Total duration

Artifacts

yow9 opened #1

Failure

9s

—

pr-checks.yml

on: pull_request_target

build5s

Annotations

1 error and 1 warning

build

Refusing to check out fork pull request code from a 'pull_request_target' workflow. This workflow runs with the base repository's GITHUB_TOKEN, secrets, default-branch cache scope, and runner access. Fetching and executing a fork's code in that trusted context commonly leads to "pwn request" vulnerabilities. To opt in, review the risks at https://gh.io/securely-using-pull_request_target and set 'allow-unsafe-pr-checkout: true' on the actions/checkout step. [Show less](#)

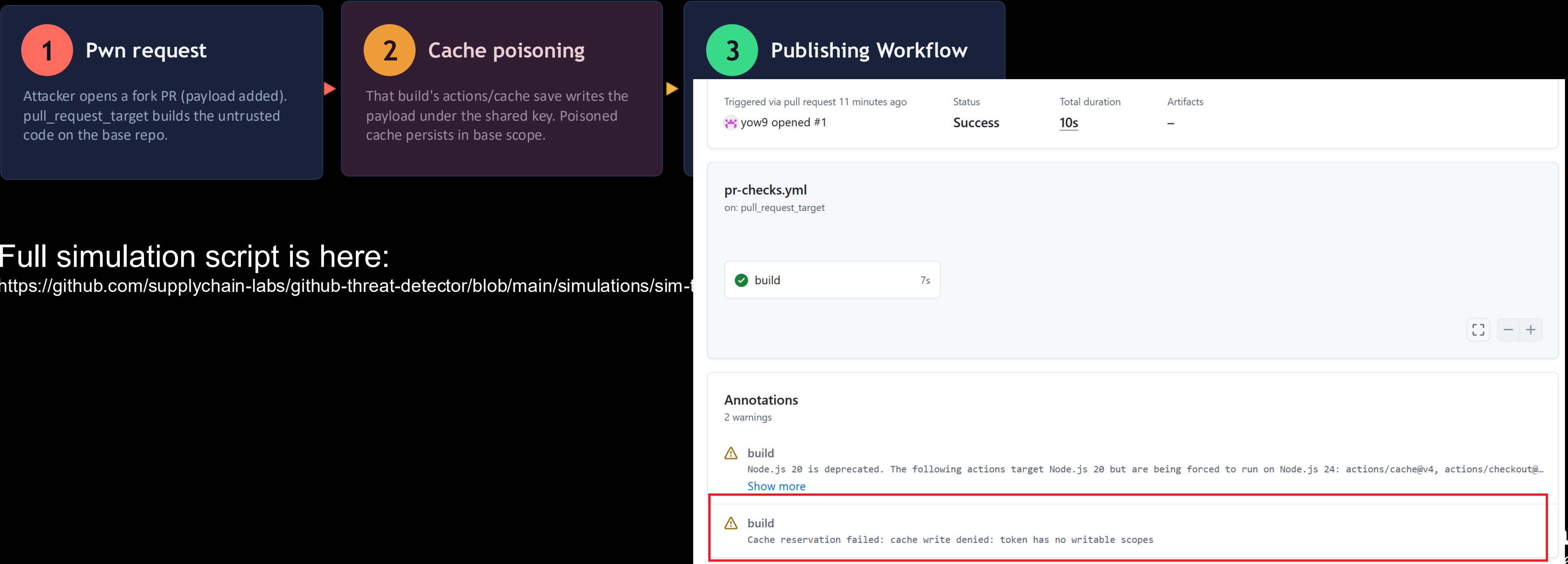
build

Node.js 20 is deprecated. The following actions target Node.js 20 but are being forced to run on Node.js 24: actions/checkout@v4. For more information see: [h...](#) [Show more](#)

Recent Github Hardening & Mitigations

Safer pull_request_target defaults (June 2026)	actions/checkout now refuses to fetch fork PR code in privileged workflows unless you explicitly opt out. (opt-out)
Read-only cache for untrusted triggers (June 2026)	Workflow runs started by non-collaborators get a cache token with read-only permission, limiting the poisoning path. (opt-out)

Example: TanStack npm supply-chain (May 2026) /simulations/sim-tanstack.sh



Full simulation script is here:
<https://github.com/supplychain-labs/github-threat-detector/blob/main/simulations/sim-tanstack.sh>

Take Aways

- **GitHub repos should be treated as part of the organization's security perimeter.**
- **Attacks against GitHub repos often share the same TTPs.**
- **Hardening is the first line of defense: built-in features can dramatically reduce the attack surface.**
- **Comprehensive monitoring requires multiple telemetries**
- **Correlating low-fidelity signals can reveal high-confidence activity.**

BRIEFINGS

black hat

THANK YOU!



yossi-weizman



morwn



github.com/supplychain-labs/github-threat-detector